



UNIVERSIDAD SANTO TOMÁS

Facultad de Ingeniería de sistemas · Ciberseguridad
Tunja, Colombia · 2026

FRAMEWORK DE AUDITORÍA WEB

Web Security Audit Framework

Para LatinoamericaComparte

Sistema objetivo: latinoamericacomparte.com

I N T E G R A N T E S

Julian Felipe Vásquez Ojeda
David Leonardo Álvarez Porras
Joseph Camilo Sáenz Rodríguez

Universidad Santo Tomás · Facultad de Ingeniería de sistemas · Ciberseguridad
Tunja, Colombia — 2026

TABLA DE CONTENIDO

TABLA DE CONTENIDO	2
1. INTRODUCCIÓN AL FRAMEWORK	4
1.1 Sistema Objetivo	4
1.2 Definición	4
1.3 Propósito	4
2. ESTRUCTURA DEL FRAMEWORK	5
2.1 Fase de Reconocimiento	5
2.2 Fase de Análisis de Tráfico HTTP	5
2.3 Fase de Escaneo de Puertos y Servicios	5
2.4 Fase de Análisis Estático del Cliente	5
2.5 Fase de Análisis Dinámico (DAST)	5
3. OBJETIVO Y ALCANCE	6
3.1 Objetivo del Framework	6
3.2 Alcance	6
4. METODOLOGÍA DE PRUEBAS	7
4.1 Enfoque Metodológico	7
5. MATRIZ DE EVALUACIÓN	8
6. CATEGORÍAS DE PRUEBA	9
6.1 Reconocimiento Pasivo (OSINT)	9
6.2 Reconocimiento Activo	9
6.3 Análisis de Tráfico HTTP	9
6.4 Análisis Estático del Cliente	9
6.5 Análisis Dinámico de Seguridad (DAST)	9
7. HERRAMIENTAS UTILIZADAS	10
8. PRUEBAS EJECUTADAS SOBRE LATINOAMERICACOMPARE.COM	11
P-01 — BurpSuite: Análisis de Capa de Aplicación HTTP	11
P-02 — DNS Footprinting: Reconocimiento Pasivo de Infraestructura	11
P-03 — Maltego: OSINT y Mapeo de Infraestructura Digital	13
P-04 — HTTrack: Clonación de Frontend e Inspección Estática	13
P-05 — Nmap: Escaneo de Puertos y Servicios	15
P-06 — OWASP ZAP: Análisis Dinámico de Seguridad (DAST)	15
9. BUENAS PRÁCTICAS DE AUDITORÍA WEB	17
9.1 Controles Técnicos	17
9.2 Controles Operativos	17
9.3 Controles Organizacionales	17
10. RECOMENDACIONES FINALES	18
10.1 Hallazgos Identificados	18
10.2 Recomendaciones Técnicas Generales	18
10.3 Diagrama General de Arquitectura y Superficie de Ataque	20
10.4 Conclusión General de la Auditoría	21

11. GLOSARIO DE TÉRMINOS	22
12. RECURSOS Y LABORATORIOS GUIADOS.....	24
12.1 Repositorio del Proyecto	24
12.2 Pentesting — Guía de Reconocimiento y Análisis	24
12.3 Scripts y Configuraciones de Herramientas	24
12.4 Documentación de las Herramientas.....	24
12.5 Estándares y Marcos de Referencia.....	24
13. BIBLIOGRAFÍA.....	25

1. INTRODUCCIÓN AL FRAMEWORK

El Framework de Auditoría Web (Web Security Audit Framework) es un marco metodológico diseñado para abordar de manera integral los riesgos de seguridad presentes en aplicaciones web, mediante la ejecución de pruebas de pentesting ético utilizando herramientas especializadas del sector.

Este marco propone un enfoque estructurado de auditoría que permite:

- Identificar vulnerabilidades en la infraestructura y superficie de ataque web.
- Analizar el tráfico HTTP/HTTPS e interceptar peticiones para detectar fallos de configuración.
- Realizar reconocimiento pasivo y activo sobre el dominio objetivo.
- Ejecutar escaneos de puertos y servicios expuestos.
- Inspeccionar estáticamente el código del lado del cliente.
- Definir recomendaciones técnicas de mitigación y control.

Su aplicación se centra en el sistema LatinoamericaComparte (<https://www.latinoamericacomparte.com/>), un CMS multipaís que gestiona contenido (noticias, testimonios, solicitudes) para múltiples países. El framework se aplica desde una perspectiva de auditor externo, sin acceso a código fuente ni infraestructura interna.

1.1 Sistema Objetivo

Sistema objetivo	LatinoamericaComparte — CMS Multipaís
URL	https://www.latinoamericacomparte.com/
Repositorio público	https://github.com/JulianFVasquez1/LatinoamericaComparte
Infraestructura identificada	Servidor Apache, dominio registrado en GoDaddy, frontend estático (HTML/CSS/JS)
Perspectiva de auditoría	Externa (caja negra / grey box)

1.2 Definición

El Framework de Auditoría Web es un marco metodológico estructurado que permite planificar, ejecutar, documentar y reportar pruebas de seguridad sobre aplicaciones web, garantizando principios de confidencialidad, integridad y disponibilidad del sistema auditado.

1.3 Propósito

Proveer a los equipos de seguridad una guía técnica reproducible para:

- Detectar vulnerabilidades en la infraestructura web y sus configuraciones.
- Evaluar el impacto de fallos de seguridad sobre el sistema objetivo.
- Estandarizar las pruebas de auditoría mediante herramientas reconocidas por la industria.
- Definir controles técnicos y contramedidas específicas.
- Fortalecer el ciclo de vida de desarrollo seguro (SSDLC) del sistema auditado.

2. ESTRUCTURA DEL FRAMEWORK

2.1 Fase de Reconocimiento

- Reconocimiento pasivo: recopilación de información sin interacción directa con el servidor (OSINT, WHOIS, DNS).
- Reconocimiento activo: interacción controlada con el objetivo para mapear infraestructura y servicios.
- Identificación de tecnologías, servidores, dominios y subdominios expuestos.
- Mapeo de la superficie de ataque.

2.2 Fase de Análisis de Tráfico HTTP

- Interceptación y análisis de peticiones y respuestas HTTP/HTTPS.
- Evaluación de cabeceras de seguridad (HSTS, CSP, X-Frame-Options, X-Content-Type-Options).
- Detección de información sensible expuesta en headers del servidor.
- Análisis de vectores de ataque en formularios y parámetros de la aplicación.

2.3 Fase de Escaneo de Puertos y Servicios

- Identificación de puertos abiertos y servicios activos en el servidor objetivo.
- Detección de versiones de software expuestas.
- Identificación de servicios innecesarios o mal configurados.
- Evaluación de la superficie de ataque a nivel de red.

2.4 Fase de Análisis Estático del Cliente

- Clonación y revisión del código fuente del lado del cliente (HTML, CSS, JS).
- Detección de credenciales duras (hardcoded), API keys o tokens expuestos.
- Mapeo de endpoints, dependencias externas y formularios.
- Identificación de rutas internas y lógica de negocio expuesta.

2.5 Fase de Análisis Dinámico (DAST)

- Ejecución de escaneos activos sobre la aplicación en tiempo real.
- Detección de vulnerabilidades en configuraciones del servidor y formularios.
- Simulación de vectores de ataque controlados.
- Clasificación de hallazgos por nivel de riesgo: Bajo / Medio / Alto / Crítico.

3. OBJETIVO Y ALCANCE

3.1 Objetivo del Framework

Definir cómo identificar, ejecutar, documentar y reportar pruebas de seguridad web sobre el sistema LatinoamericaComparte mediante herramientas de pentesting ético reconocidas por la industria.

El framework tiene como objetivo establecer un proceso de auditoría reproducible y alineado con estándares internacionales (OWASP Testing Guide, NIST), que permita detectar vulnerabilidades reales en la infraestructura, configuración y código del lado del cliente del sistema objetivo, generando evidencias documentadas y recomendaciones técnicas accionables.

3.2 Alcance

El framework se aplica sobre el sistema web externo LatinoamericaComparte, cubriendo las siguientes capas de análisis:

- Capa de red: puertos, servicios y protocolos expuestos.
- Capa de aplicación: cabeceras HTTP, formularios, endpoints y configuración del servidor web.
- Capa de cliente: código fuente estático (HTML, CSS, JS), recursos embebidos y dependencias externas.
- Capa de información: registros DNS, datos WHOIS, infraestructura de red e identidad digital.

Dominio objetivo	latinoamericacomparte.com
URL principal	https://www.latinoamericacomparte.com/
Perspectiva	Auditoría externa (sin acceso a backend ni base de datos)
Herramientas utilizadas	BurpSuite, DNS (nslookup/dig), Maltego, HTTrack, Nmap, OWASP ZAP
Tipo de pruebas	Reconocimiento pasivo, análisis de tráfico, escaneo de puertos, inspección estática, DAST
Entorno	Controlado — no se realizan ataques reales ni se afecta la disponibilidad del servicio

4. METODOLOGÍA DE PRUEBAS

Auditoría basada en herramientas especializadas de pentesting ético, con casos controlados, recopilación de evidencias y clasificación del riesgo por nivel de impacto.

El framework define una metodología de evaluación basada en auditoría web controlada, evitando la interrupción del servicio y enfocándose en la detección y documentación de vulnerabilidades reales.

4.1 Enfoque Metodológico

- Reconocimiento — Recopilación de información del objetivo mediante técnicas pasivas (OSINT, DNS, WHOIS) y activas (escaneo de puertos), sin afectar la disponibilidad del servicio.
- Definición de casos de prueba — Basados en el OWASP Testing Guide y adaptados a la superficie de ataque identificada del sistema objetivo.
- Ejecución de pruebas — En entornos controlados utilizando herramientas de la industria (BurpSuite, Nmap, ZAP, HTTrack, Maltego, DNS tools).
- Recopilación de evidencias — Capturas de pantalla, logs, reportes exportados de cada herramienta y resultados documentados por campo.
- Evaluación de hallazgos — Análisis de cada resultado comparando la configuración actual con las buenas prácticas de seguridad web.
- Clasificación del riesgo — Bajo / Medio / Alto / Crítico, basado en impacto real y facilidad de explotación.
- Registro de resultados — Documentación estructurada en matrices de evaluación con evidencias adjuntas.

5. MATRIZ DE EVALUACIÓN

Cada prueba ejecutada se documenta con la siguiente estructura estandarizada:

Campo	Descripción
ID	Identificador único de la prueba (Ej: P-01, P-02...)
Herramienta	Herramienta utilizada para ejecutar la prueba
Tipo de prueba	Reconocimiento / Análisis HTTP / Escaneo de puertos / Análisis estático / DAST
Descripción	Explicación del escenario y objetivo de la prueba
Entrada usada	Comando, configuración o parámetro utilizado
Respuesta esperada	Comportamiento seguro o configuración correcta esperada
Respuesta obtenida	Resultado real observado durante la ejecución
Impacto	Consecuencia del hallazgo para la seguridad del sistema
Severidad	Nivel de riesgo: Bajo / Medio / Alto / Crítico
Recomendación	Acción técnica de mitigación propuesta

6. CATEGORÍAS DE PRUEBA

6.1 Reconocimiento Pasivo (OSINT)

Recopilación de información pública del sistema objetivo sin interacción directa con el servidor. Incluye consultas DNS, análisis WHOIS, mapeo de infraestructura y correlación de datos mediante herramientas de inteligencia de fuentes abiertas.

- Herramientas: Maltego, nslookup, dig.
- Objetivo: mapear la infraestructura digital, registros de red y datos expuestos públicamente.

6.2 Reconocimiento Activo

Interacción directa y controlada con el sistema objetivo para identificar puertos abiertos, servicios activos y versiones de software expuestas.

- Herramientas: Nmap.
- Objetivo: identificar la superficie de ataque a nivel de red y servicios.

6.3 Análisis de Tráfico HTTP

Interceptación, inspección y análisis de las peticiones y respuestas HTTP/HTTPS entre el cliente y el servidor para detectar configuraciones inseguras, cabeceras faltantes e información sensible expuesta.

- Herramientas: BurpSuite.
- Objetivo: evaluar el hardening del servidor web y detectar vectores de ataque en la capa de aplicación.

6.4 Análisis Estático del Cliente

Clonación y revisión offline del código fuente del frontend para identificar credenciales expuestas, endpoints no documentados, dependencias externas y lógica de negocio accesible públicamente.

- Herramientas: HTTrack, grep/comandos de consola.
- Objetivo: detectar información sensible embebida en el código del lado del cliente.

6.5 Análisis Dinámico de Seguridad (DAST)

Ejecución de escaneos activos sobre la aplicación en tiempo real mediante proxies de interceptación y escáneres automatizados para detectar vulnerabilidades en configuraciones, formularios y políticas de seguridad del servidor.

- Herramientas: OWASP ZAP.
- Objetivo: identificar vulnerabilidades explotables en tiempo de ejecución mediante análisis dinámico.

7. HERRAMIENTAS UTILIZADAS

Herramienta	Fase	Propósito
BurpSuite	Análisis de Tráfico HTTP	Interceptación y análisis de peticiones/respuestas HTTP, evaluación de cabeceras de seguridad
DNS (nslookup/dig)	Reconocimiento Pasivo	Mapeo de registros DNS, jerarquía de servidores, detección de DNSSEC
Maltego	OSINT / Reconocimiento Pasivo	Correlación visual de infraestructura: IP, NS, MX, WHOIS, bloques de red
HTTrack	Análisis Estático del Cliente	Clonación recursiva del frontend para inspección offline de código fuente
Nmap	Escaneo de Puertos y Servicios	Identificación de puertos abiertos, servicios activos y versiones expuestas
OWASP ZAP	Análisis Dinámico (DAST)	Escaneo activo automatizado, spider/AJAX spider, detección de vulnerabilidades en tiempo real

8. PRUEBAS EJECUTADAS SOBRE LATINOAMERICACOMPARE.COM

Las siguientes pruebas fueron ejecutadas sobre el sistema externo <https://www.latinoamericacomparte.com/> utilizando herramientas de pentesting ético. Los campos marcados como [Por completar] se rellenan durante la ejecución de las pruebas.

P-01 — BurpSuite: Análisis de Capa de Aplicación HTTP

ID / Herramienta	P-01 — BurpSuite
Tipo de prueba	Análisis de Tráfico HTTP / Reconocimiento activo
Descripción	Evaluación general de la capa de aplicación mediante la interceptación de respuestas HTTP para verificar las políticas de endurecimiento (Hardening) y la exposición de metadatos del servidor.
Entrada usada	Interceptación de la petición raíz GET / HTTP/2 hacia el dominio latinoamericacomparte.com usando Burp Browser.
Respuesta esperada	El servidor debe responder con firmas ofuscadas y retornar los encabezados de seguridad esenciales (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options) configurados para proteger al cliente.
Respuesta obtenida	Se identificó la divulgación explícita del software en la línea Server: Apache junto a la ausencia total de todas las cabeceras de seguridad evaluadas (HSTS, X-Frame, X-Content-Type).
Impacto	Exposición de la plataforma a fases de reconocimiento dirigido por atacantes, riesgo de interceptación de tráfico local (SSL Strip) y vulnerabilidad a la clonación/enmarcado de la web (Clickjacking).
Severidad	MEDIA
Recomendación	Modificar el archivo de configuración de Apache (.htaccess) para ocultar los tokens del servidor e inyectar de forma obligatoria las directivas de seguridad ausentes (HSTS, X-Frame-Options, X-Content-Type-Options).

P-02 — DNS Footprinting: Reconocimiento Pasivo de Infraestructura

ID / Herramienta	P-02 — DNS (nslookup / dig)
Tipo de prueba	Reconocimiento Pasivo / OSINT / DNS Footprinting
Descripción	Mapeo no intrusivo de la infraestructura lógica, jerarquía de resolución y controles de integridad del dominio mediante consultas públicas del sistema de nombres.
Entrada usada	Ejecución secuencial de comandos nslookup y dig (con flags +trace, DNSKEY, DS) sobre el dominio latinoamericacomparte.com desde Kali Linux.
Respuesta esperada	Identificación de la IP de hosting, árbol jerárquico de servidores autoritativos, descarte de servicios innecesarios y verificación de firmas de seguridad criptográfica (DNSSEC).
Respuesta obtenida	IP Resuelta: 66.33.22.47 (Registro A único con TTL dinámico de 60s). Jerarquía: delegado desde Root pasando por TLD .app de Google hasta ns1.railway.app. Sin registros MX activos. DNSSEC: No implementado (unsigned).
Impacto	La ausencia de DNSSEC facilita un vector técnico para ataques de envenenamiento de caché (DNS Cache Poisoning) o suplantación de identidad (DNS Spoofing) en entornos de red locales.

Severidad	BAJA (fase informativa de reconocimiento)
Recomendación	Evaluar con el proveedor (Railway) o mediante un proxy/WAF externo como Cloudflare la activación de DNSSEC para extender la cadena de confianza cifrada hasta el subdominio final.

P-03 — Maltego: OSINT y Mapeo de Infraestructura Digital

ID / Herramienta	P-03 — Maltego
Tipo de prueba	Reconocimiento Pasivo / OSINT
Descripción	Recolección de información pública y mapeo visual de la infraestructura digital del dominio latinoamericacomparte.com para identificar vectores de ataque potenciales sin interactuar de forma intrusiva con los servidores.
Entrada usada	Dominio objetivo: latinoamericacomparte.com con transformaciones estándar de infraestructura (DNS, WHOIS, Netblock).
Respuesta esperada	Identificación y aislamiento de componentes clave: registros MX, servidores de nombres (NS), direccionamiento IP público, bloques de red vinculados y datos del registrador del dominio.
Respuesta obtenida	IP del servidor web: 64.202.187.143. Bloque de red /24 administrado por GoDaddy. Servidores de nombres: ns05.domaincontrol.com. Servidor de correo: mail.latinamericacomparte.com. Correos técnicos expuestos: dns@jomax.net.
Impacto	Fuga de información técnica (Information Disclosure). La consolidación del mapa de red facilita a un atacante la fase de footprinting para planificar ataques dirigidos contra el servidor de correo o ejecutar ingeniería social.
Severidad	BAJA (reconocimiento inicial / informativo)
Recomendación	Implementar servicios de privacidad de WHOIS para ocultar datos de contacto técnico. Evaluar la restricción de transferencias de zona DNS (Zone Transfers) no autorizadas y monitorear subdominios expuestos.

P-04 — HTTrack: Clonación de Frontend e Inspección Estática

ID / Herramienta	P-04 — HTTrack
Tipo de prueba	Análisis Estático del Cliente / Reconocimiento Pasivo
Descripción	Clonación recursiva del sitio web latinoamerica-comparte.vercel.app para inspección estática offline del código fuente del frontend. Se descargaron todos los recursos accesibles públicamente (HTML, CSS, JS, imágenes y fuentes) con el objetivo de analizar la estructura del cliente, detectar credenciales expuestas, endpoints no documentados y dependencias externas.
Entrada usada	Ejecución del comando: httrack "https://latinoamerica-comparte.vercel.app/" -O "\$HOME/lab_httrack_vercel" "+*.vercel.app/*" "+*.css" "+*.js" "+*.png" "+*.jpg" "+*.jpeg" "+*.gif" -F "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36" -v. Ejecutado desde Kali Linux en el directorio ~/lab_httrack_vercel.
Respuesta esperada	Se esperaba clonar correctamente el frontend del sitio, obteniendo los archivos HTML, CSS y JS accesibles públicamente. No se esperaba encontrar credenciales expuestas, tokens de autenticación, API keys ni rutas internas en el código del cliente. Los recursos externos debían cargarse desde dominios de confianza con atributos de integridad SRI.
Respuesta obtenida	Clonación completada en 4 minutos 36 segundos. Se escanearon 7 enlaces y se escribieron 5 archivos (979684 bytes). Estructura obtenida: index.html, backblue.gif, fade.gif, directorio hts-cache y subdirectorio latinoamerica-comparte.vercel.app/ con index.html y carpeta assets/. Al inspeccionar el JS minificado (assets/index-BCerPuvB.js) mediante grep con patrones 'api', 'fetch', 'token', 'key' y 'http', se identificaron referencias a endpoints internos, llamadas fetch con cabeceras de autenticación, tokens de formulario y patrones de manejo de errores HTTP. Se registró 1 error de tiempo de conexión al acceder a robots.txt y 1 advertencia de reintento en recursos de fuentes.

Impacto	La exposición de lógica de negocio en el JS minificado del cliente permite a un atacante mapear endpoints internos, identificar patrones de autenticación y comprender el flujo de peticiones de la aplicación sin acceso al servidor. La ausencia de ofuscación real del código facilita la ingeniería inversa del frontend. La falta de robots.txt impide controlar el rastreo automatizado del sitio.
Severidad	BAJA
Recomendación	Implementar ofuscación real del código JavaScript en producción para dificultar la ingeniería inversa. Crear un archivo robots.txt que restrinja el rastreo de rutas sensibles. Revisar el código JS expuesto para eliminar referencias a endpoints internos o patrones de autenticación que no deban ser públicos. Evaluar el uso de variables de entorno del lado del servidor para gestionar configuraciones sensibles.

P-05 — Nmap: Escaneo de Puertos y Servicios

ID / Herramienta	P-05 — Nmap
Tipo de prueba	Reconocimiento Activo / Escaneo de Puertos y Servicios
Descripción	Escaneo de puertos y servicios sobre el dominio latinoamerica-comparte.vercel.app para identificar la superficie de ataque a nivel de red. Se ejecutaron múltiples fases: identificación de puertos abiertos, detección de versiones de servicios y fingerprinting del sistema operativo. Se realizó reconocimiento previo de red local (ip a, ip route, arp -a) para verificar la configuración del entorno de auditoría.
Entrada usada	Secuencia de comandos desde Kali Linux: (1) ip a e ip route para verificar configuración de red del auditor; (2) ping latinoamerica-comparte.vercel.app (IP resuelta: 216.198.79.67); (3) nslookup latinoamerica-comparte.vercel.app (IPs: 216.198.79.67 y 64.29.17.67); (4) sudo nmap -Pn latinoamerica-comparte.vercel.app para escaneo básico de puertos; (5) sudo nmap -Pn -sV para detección de versiones; (6) sudo nmap -Pn -O para fingerprinting de sistema operativo.
Respuesta esperada	Se esperaba encontrar únicamente los puertos 80 (HTTP) y 443 (HTTPS) abiertos. No se esperaba encontrar servicios adicionales como FTP (21) o SMTP (25). El sistema operativo debía corresponder a un servidor Linux típico de plataformas de hosting en la nube.
Respuesta obtenida	IP principal resuelta: 216.198.79.67 (dirección alternativa: 64.29.17.67). Puertos abiertos: 21/tcp (ftp), 25/tcp (smtp), 80/tcp (http), 443/tcp (https). Puerto cerrado: 139/tcp (netbios-ssn). En el escaneo -sV los servicios 25, 80 y 443 aparecieron como tcpwrapped y 21/tcp como ftp?. El fingerprinting de OS (-O) no fue concluyente; la estimación más probable fue Apple iOS 15.x/16.x (89%), resultado atribuido a que el tráfico pasa por la CDN de Vercel. Tiempo total de escaneo: 193.82 segundos.
Impacto	La presencia de los puertos 21 (FTP) y 25 (SMTP) representa una superficie de ataque adicional no esperada para un sitio web estático. Aunque estos servicios pueden pertenecer a la infraestructura compartida de Vercel, su presencia amplía el perfil de riesgo. El resultado no concluyente del fingerprinting confirma que el tráfico está mediado por CDN, lo que dificulta el reconocimiento directo del servidor real.
Severidad	BAJA — Los puertos detectados pertenecen a la infraestructura compartida de Vercel (CDN/hosting), no a servicios propios del sistema auditado. No se identificaron vulnerabilidades explotables directamente en los servicios expuestos.
Recomendación	Verificar con el proveedor Vercel si los puertos 21 (FTP) y 25 (SMTP) pertenecen a la infraestructura compartida o corresponden a servicios propios del proyecto. En caso de ser servicios propios, deshabilitar FTP y SMTP si no son requeridos. Documentar la arquitectura de red real para distinguir servicios del proveedor de los propios. Considerar el uso de Cloudflare u otro WAF/proxy inverso para enmascarar la infraestructura real del servidor.

P-06 — OWASP ZAP: Análisis Dinámico de Seguridad (DAST)

ID / Herramienta	P-06 — OWASP ZAP
Tipo de prueba	Análisis Dinámico de Seguridad (DAST) / Escaneo Automatizado
Descripción	Escaneo dinámico automatizado de seguridad (DAST) sobre latinoamericacomparte.com utilizando OWASP ZAP 2.17.0. Se ejecutó un análisis activo sobre el sitio para identificar vulnerabilidades en cabeceras HTTP, configuración del servidor Apache, políticas CORS, protección contra XSS y clickjacking, integridad de recursos externos (SRI) y exposición de tecnología. El escaneo analizó 69 endpoints detectados, clasificando 23 alertas en niveles de riesgo Medium, Low e Informational.
Fecha del análisis	26 de mayo de 2026

Entrada usada	Escaneo activo con OWASP ZAP 2.17.0 sobre https://latinoamericacomparte.com . Objetivo principal: dominio raíz. Tráfico adicional analizado desde cdnjs.cloudflare.com y servicios Mozilla.
Respuesta esperada	El servidor debería retornar cabeceras de seguridad completas (Content-Security-Policy, Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options), no exponer la versión del servidor Apache, implementar tokens CSRF en formularios, restringir el acceso CORS a dominios autorizados y verificar criptográficamente los recursos externos mediante atributos SRI (integrity). No se espera la detección de vulnerabilidades críticas explotables.
Respuesta obtenida	Se detectaron 23 alertas: 0 High, 5 Medium, 4 Low, 14 Informational. Hallazgos Medium: ausencia de cabecera CSP (3 instancias), ausencia de tokens Anti-CSRF (1), mala configuración CORS con wildcard (2), ausencia de protección anti-clickjacking (1), recursos externos sin atributo SRI (2). Hallazgos Low: HSTS no implementado (6), X-Content-Type-Options faltante (6), exposición de timestamps Unix (4), carga de JavaScript desde dominios externos (1). El servidor expone cabecera Server: Apache. No se detectó SQL Injection, RCE, Path Traversal, LFI/RFI, XXE ni credenciales expuestas. El 96% de las respuestas registradas como lentas. Tecnologías identificadas: Apache, Cloudflare, Varnish, HTTP/3, Google Font API, Web3Forms, cdnjs.
Impacto	La ausencia de CSP expone el sitio a inyección de scripts maliciosos (XSS), robo de cookies y manipulación del DOM. La falta de tokens CSRF permite la ejecución de solicitudes falsificadas. La configuración CORS con wildcard (*) puede exponer APIs a dominios no autorizados. La ausencia de X-Frame-Options facilita ataques de Clickjacking. Los recursos externos sin SRI quedan vulnerables a compromiso de CDN. La falta de HSTS permite downgrade a HTTP. La exposición de timestamps Unix y la cabecera Server: Apache facilitan el fingerprinting del sistema.
Severidad	MEDIA — Sin vulnerabilidades críticas ni altas. Seguridad general: 6/10. Configuración del servidor: 4/10. Riesgo crítico inmediato: Bajo. Riesgo acumulativo: Medio.
Recomendación	Alta prioridad: implementar cabeceras HTTP de seguridad en Apache (Content-Security-Policy, Strict-Transport-Security, X-Frame-Options SAMEORIGIN, X-Content-Type-Options nosniff). Media prioridad: agregar atributos integrity y crossorigin a todos los recursos externos, restringir CORS evitando Access-Control-Allow-Origin: *, ocultar la firma del servidor. Baja prioridad: crear archivo robots.txt, implementar tokens CSRF en formularios, optimizar rendimiento del sitio.

9. BUENAS PRÁCTICAS DE AUDITORÍA WEB

El framework establece un conjunto de buenas prácticas para garantizar auditorías seguras, reproducibles y alineadas con estándares internacionales:

9.1 Controles Técnicos

- Ejecutar todas las pruebas desde entornos controlados (máquinas virtuales Kali Linux, entornos de laboratorio).
- Utilizar exclusivamente herramientas reconocidas por la industria (OWASP ZAP, Burp Suite, Nmap, Metasploit, HTTrack).
- Verificar cabeceras HTTP de seguridad en cada auditoría: HSTS, CSP, X-Frame-Options, X-Content-Type-Options.
- Documentar con capturas de pantalla y logs cada prueba ejecutada.
- No realizar pruebas destructivas ni que afecten la disponibilidad del servicio.
- Aplicar el principio de mínimo privilegio en toda interacción con el sistema objetivo.

9.2 Controles Operativos

- Monitorear el tráfico interceptado y registrar todos los hallazgos en la matriz de evaluación.
- Mantener trazabilidad de cada herramienta utilizada, comandos ejecutados y resultados obtenidos.
- Revisar y actualizar el framework periódicamente según nuevas vulnerabilidades y herramientas.

9.3 Controles Organizacionales

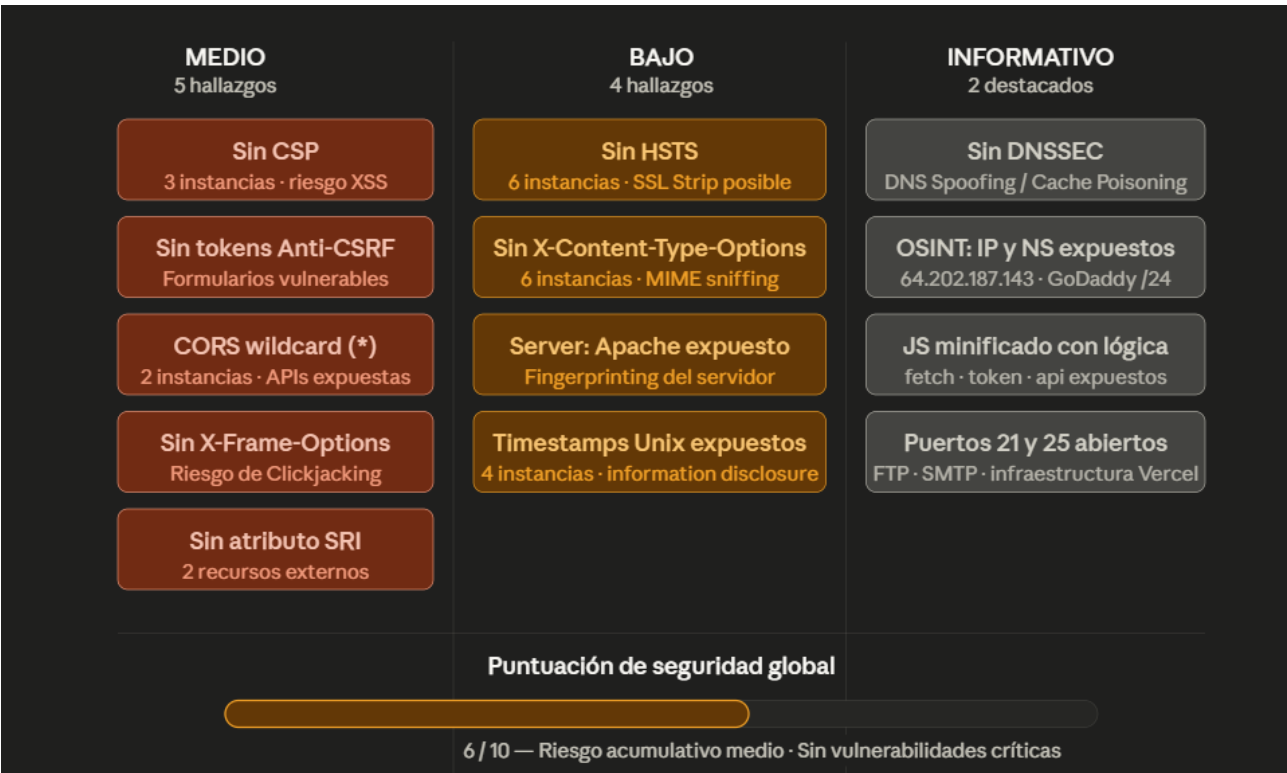
- Contar con autorización explícita antes de ejecutar cualquier prueba sobre el sistema objetivo.
- Realizar auditorías adversariales periódicas sobre el sistema.
- Capacitar al equipo en el uso correcto de las herramientas y en la interpretación de resultados.

10. RECOMENDACIONES FINALES

Las siguientes recomendaciones se derivan de los hallazgos identificados durante la auditoría externa del sistema LatinoamericaComparte. Deben ser validadas e implementadas por el equipo de desarrollo antes de llevar el sistema a producción.

10.1 Hallazgos Identificados

Severidad	Hallazgo
MEDIO	Servidor Apache con firma expuesta (cabecera Server: Apache): facilita el reconocimiento dirigido por atacantes.
MEDIO	Ausencia total de cabeceras de seguridad HTTP: no se encontraron HSTS, X-Frame-Options, X-Content-Type-Options ni CSP, exponiendo el sitio a Clickjacking, SSL Strip e inyección de código.
BAJO	DNSSEC no implementado: el dominio es vulnerable a DNS Cache Poisoning y DNS Spoofing.
BAJO	Información de infraestructura expuesta vía OSINT: IP real (64.202.187.143), bloque GoDaddy /24, servidores NS y correos técnicos descubiertos con Maltego.



10.2 Recomendaciones Técnicas Generales

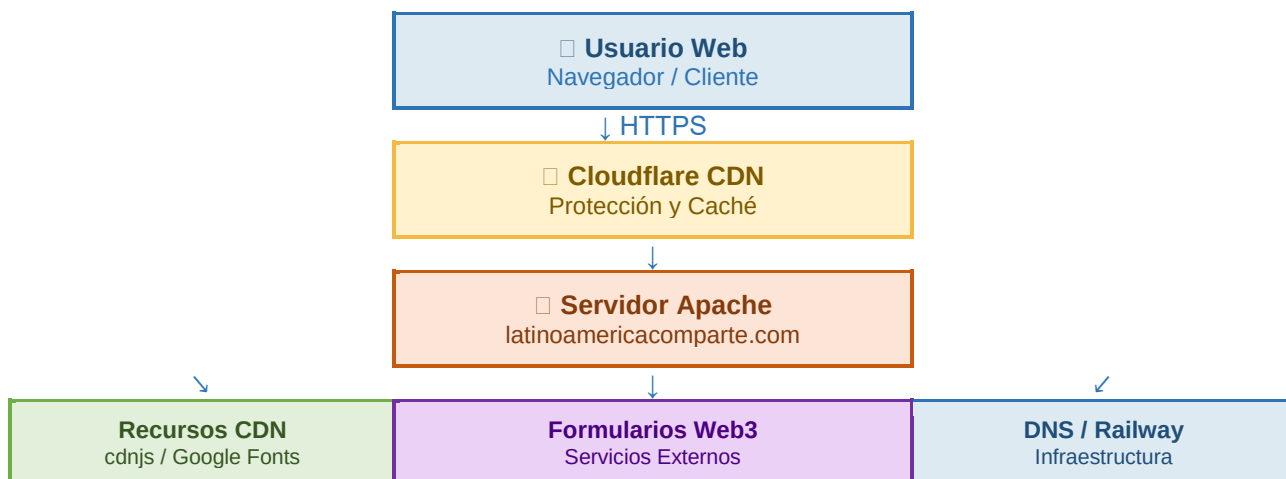
- Ocultar la firma del servidor Apache modificando el archivo .htaccess (ServerTokens Prod / ServerSignature Off).
- Implementar de forma inmediata las cabeceras HTTP defensivas: Strict-Transport-Security, X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff y Content-Security-Policy.
- Evaluar la activación de DNSSEC con el proveedor Railway o mediante un proxy/WAF externo como Cloudflare.
- Implementar servicios de privacidad de WHOIS para ocultar los datos de contacto técnico expuestos públicamente.

- Configurar tokens Anti-CSRF en todos los formularios del sitio para prevenir ataques de falsificación de solicitudes.
- Monitorear periódicamente los subdominios expuestos para detectar servicios desactualizados o mal configurados.
- Corregir los enlaces rotos (Error 404) detectados en el menú de navegación del sitio.

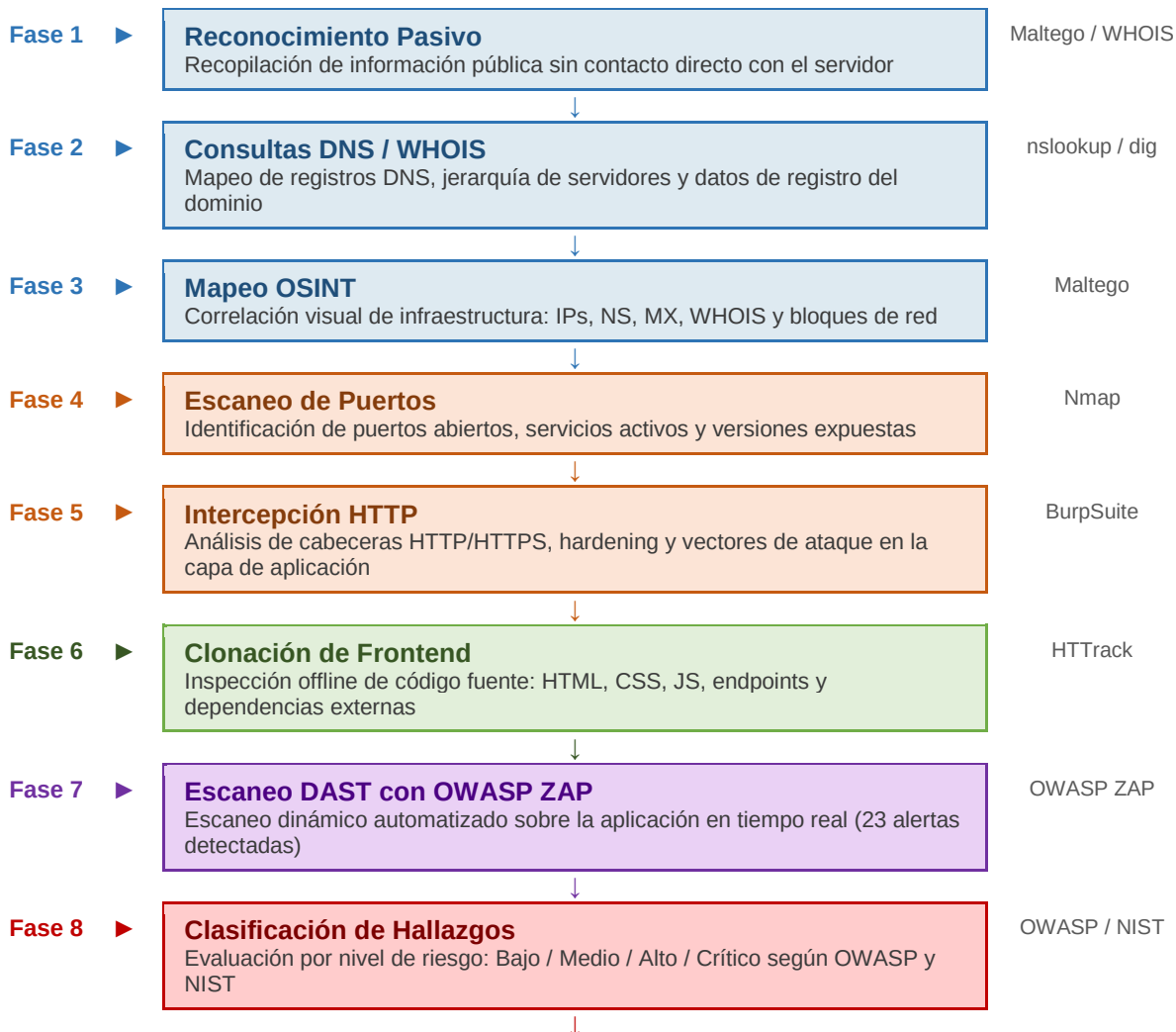
10.3 Diagrama General de Arquitectura y Superficie de Ataque

Arquitectura General del Sistema

El sistema LatinoamericaComparte opera bajo una arquitectura web pública basada en servicios externos, frontend estático y componentes distribuidos. Desde la perspectiva de auditoría externa se identificó la siguiente estructura de alto nivel:



Flujo General de Auditoría



Fase 9 ▶

Recomendaciones Técnicas

Propuestas de mitigación y controles de hardening alineados con OWASP y NIST

Informe Final

10.4 Conclusión General de la Auditoría

La auditoría externa realizada sobre el sistema LatinoamericaComparte permitió identificar múltiples debilidades relacionadas principalmente con configuraciones de seguridad web, endurecimiento del servidor Apache y ausencia de políticas modernas de protección HTTP.

Desde la perspectiva metodológica, el framework permitió ejecutar un proceso estructurado de reconocimiento, análisis y evaluación utilizando herramientas especializadas de pentesting ético ampliamente reconocidas por la industria. La combinación de técnicas OSINT, análisis HTTP, escaneo de puertos, revisión estática y pruebas DAST permitió obtener una visión integral de la superficie de ataque expuesta públicamente.

Los resultados evidencian que el sistema no presenta vulnerabilidades críticas explotables de forma inmediata, tales como Remote Code Execution (RCE), SQL Injection, Path Traversal o exposición directa de credenciales. Sin embargo, se identificaron múltiples configuraciones inseguras que incrementan el riesgo acumulativo del sistema frente a ataques modernos sobre aplicaciones web.

Hallazgos más relevantes identificados:

#	Hallazgo identificado
1	Ausencia de cabeceras HTTP defensivas (CSP, HSTS, X-Frame-Options, X-Content-Type-Options)
2	Exposición de información técnica del servidor Apache (cabecera Server: Apache)
3	Configuración CORS permisiva con wildcard (*) en cabecera Access-Control-Allow-Origin
4	Ausencia de controles Anti-CSRF en formularios del sitio
5	Recursos externos cargados sin validación criptográfica SRI (atributo integrity ausente)
6	Exposición de información de infraestructura mediante técnicas OSINT (IP real, bloques de red, NS)

A nivel de madurez de seguridad, el sistema presenta un nivel funcional aceptable para entornos de baja criticidad, pero requiere fortalecer sus controles de hardening antes de considerarse completamente alineado con buenas prácticas modernas de seguridad web.

La implementación de las recomendaciones técnicas propuestas permitiría reducir significativamente la superficie de ataque y mejorar la resiliencia del sistema frente a amenazas comunes orientadas a aplicaciones web públicas.

Finalmente, el framework desarrollado demuestra la viabilidad de ejecutar auditorías externas controladas utilizando únicamente herramientas de software libre y metodologías reconocidas internacionalmente, manteniendo un enfoque ético, reproducible y alineado con estándares OWASP y NIST.

11. GLOSARIO DE TÉRMINOS

Término	Definición
Pentesting ético	Pruebas de penetración realizadas con autorización explícita sobre un sistema, con el objetivo de identificar vulnerabilidades antes de que un atacante las explote.
OSINT	Open Source Intelligence. Recopilación de información a partir de fuentes públicas para apoyar fases de reconocimiento en auditorías de seguridad.
DNS Footprinting	Proceso de reconocimiento pasivo que recopila información del sistema de nombres de dominio para mapear la infraestructura objetivo.
DNSSEC	Extensión de seguridad del protocolo DNS que permite firmar criptográficamente los registros DNS para evitar su falsificación o envenenamiento.
DNS Cache Poisoning	Ataque que introduce registros DNS falsos en la caché de un servidor resolutor para redirigir el tráfico hacia servidores maliciosos.
Reconocimiento pasivo	Fase de auditoría en la que se recopila información del objetivo sin interacción directa con sus servidores, usando únicamente fuentes públicas.
Reconocimiento activo	Fase de auditoría en la que se interactúa directamente con el sistema objetivo para identificar puertos, servicios y versiones de software expuestas.
BurpSuite	Plataforma integrada para pruebas de seguridad en aplicaciones web. Actúa como proxy local que permite interceptar, inspeccionar y modificar peticiones HTTP/HTTPS en tiempo real.
Nmap	Herramienta de código abierto para el escaneo de redes y puertos. Permite descubrir hosts activos, servicios y versiones de software expuestos en una red.
OWASP ZAP	Escáner y proxy de interceptación dinámico de aplicaciones web. Permite descubrir fallos de configuración, vulnerabilidades en formularios y ausencia de directivas de seguridad en tiempo real.
HTTrack	Herramienta de código abierto para la clonación recursiva de sitios web. Permite construir una réplica local del frontend para análisis estático offline.
Maltego	Aplicación gráfica de minería de datos OSINT que correlaciona infraestructura de red, IPs, dominios, correos e identidades digitales en un mapa visual de dependencias.
DAST	Dynamic Application Security Testing. Metodología de pruebas de seguridad en ejecución (caja negra) que analiza una aplicación interactuando con ella desde el exterior.
HSTS	HTTP Strict Transport Security. Cabecera que obliga al navegador a comunicarse exclusivamente mediante HTTPS, previniendo ataques de SSL Strip.
Content Security Policy (CSP)	Cabecera de seguridad HTTP que restringe los recursos (JS, CSS, imágenes) que el navegador puede cargar y ejecutar, mitigando ataques XSS.
Clickjacking	Técnica de ataque que embebe una página web legítima en un iframe invisible para engañar al usuario y redirigir sus interacciones.
CSRF	Cross-Site Request Forgery. Vulnerabilidad que induce a un usuario autenticado a realizar acciones involuntarias en una aplicación web, mitigada mediante tokens criptográficos.
Information Disclosure	Anomalía de seguridad en la que un sistema expone involuntariamente datos técnicos, metadatos o credenciales a usuarios no autorizados.
Zone Transfer (AXFR)	Mecanismo de replicación de registros DNS entre servidores. Mal configurado, permite descargar la base de datos completa de subdominios de una red.

Término	Definición
Footprinting	Proceso sistemático de recopilación de información sobre el sistema objetivo en las fases iniciales de una auditoría de seguridad.
OWASP	Open Web Application Security Project. Organización sin fines de lucro que publica guías, herramientas y estándares para la seguridad de aplicaciones web.
SSDLC	Secure Software Development Life Cycle. Ciclo de vida de desarrollo de software que integra prácticas de seguridad en cada fase del proceso.

12. RECURSOS Y LABORATORIOS GUIADOS

12.1 Repositorio del Proyecto

<https://github.com/JulianFVasquez1/LatinoamericaComparte>

12.2 Pentesting — Guía de Reconocimiento y Análisis

El repositorio contiene la configuración de OWASP ZAP para el escaneo del sistema LatinoamericaComparte, incluyendo el perfil de autenticación y los endpoints objetivo. Se documenta el proceso de reconocimiento pasivo (análisis de headers, enumeración de rutas) y activo (escaneo de puertos con Nmap y vulnerabilidades con ZAP).

12.3 Scripts y Configuraciones de Herramientas

Se incluyen configuraciones exportadas de BurpSuite, colecciones de pruebas, resultados de Maltego y comandos DNS documentados para reproducir los escenarios de auditoría de forma controlada.

12.4 Documentación de las Herramientas

- OWASP ZAP: <https://www.zaproxy.org/docs/>
- Burp Suite: <https://portswigger.net/burp/documentation>
- Nmap Reference Guide: <https://nmap.org/book/man.html>
- Maltego Documentation: <https://docs.maltego.com/>
- HTTrack Website Copier: <https://www.httrack.com/html/fcguide.html>

12.5 Estándares y Marcos de Referencia

- OWASP Testing Guide v4.2: <https://owasp.org/www-project-web-security-testing-guide/>
- OWASP API Security Top 10: <https://owasp.org/www-project-api-security/>
- NIST AI Risk Management Framework:
<https://www.nist.gov/system/files/documents/2023/01/26/AI%20RMF%201.0.pdf>
- W3C Content Security Policy: <https://w3.org/tr/csp/>

13. BIBLIOGRAFÍA

Referencias en norma APA (7.^a edición)

- OWASP Foundation. (2023). OWASP Web Security Testing Guide (v4.2). <https://owasp.org/www-project-web-security-testing-guide/>
- OWASP Foundation. (2023). OWASP API Security Top 10. <https://owasp.org/www-project-api-security/>
- OWASP Foundation. (2022). OWASP ZAP (Zed Attack Proxy). <https://owasp.org/www-project-zap/>
- PortSwigger Ltd. (2024). Burp Suite Community Edition — User Guide. <https://portswigger.net/burp/documentation>
- Nmap Project. (2024). Nmap Network Scanning — Reference Guide. <https://nmap.org/book/man.html>
- Maltego Technologies. (2024). Maltego Standard Transforms & Documentation. <https://docs.maltego.com/>
- HTTrack. (2023). HTTrack Website Copier — User Manual. <https://www.httrack.com/html/fcguide.html>
- W3C. (2023). Content Security Policy (CSP) Specification. <https://w3.org/tr/csp/>
- MDN Web Docs. (2023). HTTP Headers. Mozilla Developer Network. <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers>
- National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). <https://doi.org/10.6028/NIST.AI.100-1>
- Verimatrix. (2025). Visión general de los ataques de inyección. <https://www.verimatrix.com/es/ciberseguridad/faq/overview-of-injection-attacks/>
- Vásquez Ojeda, J. F., Álvarez Porras, D. L., & Sáenz Rodríguez, J. C. (2026). LatinoamericaComparte — CMS Multipaís [Repositorio de código fuente]. GitHub. <https://github.com/JulianFVasquez1/LatinoamericaComparte>